



Blueprint for Email Security Platforms

Notes from Session 2 of 3, part of the CLC: 2026 Certified AI Email Security Specialist learning path: SEG vs. API architecture, the human-centric platform stack, and how Nexus AI models stop AI-generated attacks.

PRESENTER

Matt Cooke, Director, Cybersecurity Strategy

ON THIS PAGE

- 01 Why the platform question matters
- 02 SEG vs. API: the two architectures
- 03 Choosing your architecture
- 04 The human-centric platform blueprint
- 05 Training AI: big LLMs to distilled Nexus models
- 06 Stopping AI-generated attacks: two worked examples
- 07 Visibility & human risk management
- 08 Closing summary

QUICK RECALL

SEG = pre-delivery, MX-record gatekeeper. API/ICES = post-delivery, reads mail via Microsoft Graph after it lands. Most orgs end up running both, layered.

01 · THE PROBLEM

Why the platform question matters

Threat volume and sophistication are both climbing at once, and the tooling decision (gateway vs. API vs. both) determines how much of it your team ever

has to see.

RIISING THREAT CATEGORIES (YOY)

Phishing

+68%

Malware

+20%

BEC

+8%

TOAD

+3.5%

WHAT'S CHANGING IN KIND, NOT JUST VOLUME

More targeted attacks

BEC, ransomware, invoice fraud, thread hijacking

More work disruption

Spam bombing, graymail, missing/misfiled mail, alert-triage overload

The human cost: 94% of targeted attacks still succeed via email despite high awareness of the risk, at an average cost of \$4.8M per incident, and an estimated 40% of BEC emails are now AI-generated.

Microsoft 365 is losing ground: native M365 email security saw threats reaching users climb 45.8% year over year, the core argument for adding a dedicated layer on top of native defenses.

02 · TWO PHILOSOPHIES

SEG vs. API: the two architectures

Every add-on email security platform is built on one of two delivery models: where it sits relative to the moment the email lands in the mailbox.

SECURE EMAIL GATEWAY (SEG): PRE-DELIVERY

Sits in front of the mailbox: the MX record routes mail through it first, so it can block or decorate a message before it ever reaches the inbox. Only clean mail gets through.

API / ICES: POST-DELIVERY

Mail lands first, then a Microsoft Graph API integration reads it and scores it. High-risk mail is auto-quarantined; borderline mail is soft-quarantined with an educational banner until the user or the system confirms it's safe.

ICES stands for **Integrated Cloud Email Security**, the formal name for the API approach, since it plugs into the cloud mailbox itself rather than sitting in front of it.

03 · DECISION FRAMEWORK

Choosing your architecture

Three questions decide it: time to value, how Microsoft-centric the environment is, and how complex the existing mail routing already is.

CHOOSE SEG WHEN...

- Protection needs to be maximized, pre-delivery through click-time.
- Mail flow needs custom, condition-based policies.
- A mature security team can own granular configuration.

CHOOSE API WHEN...

- Low-touch security with simple setup is the priority.
- An existing Microsoft SEG just needs post-delivery coverage added.
- Email infrastructure is standard, nothing bespoke.

In practice, most mature setups run both, layered, rather than picking one.

04 · THE BLUEPRINT

The human-centric platform blueprint

One continuous pipeline runs from before an email ever arrives to the moment someone clicks a link inside it, in four layers.

THREAT INTELLIGENCE · PRE-DELIVERY

Sender/domain reputation, DMARC and authentication checks, and supplier-risk signals catch what's already known bad.

AI & ML DETECTION · PRE & POST

Content- and behavior-trained models, sandboxing, and semantic LLM detection catch what's novel, not just known.

BEHAVIORAL AI • POST-DELIVERY

Adaptive DLP and relationship-graph-driven response automation watch what happens after delivery.

HUMAN RISK

MANAGEMENT • CLICK TIME

Security awareness training, URL rewriting/isolation, and ATO detection protect the person, not just the inbox.

05 • UNDER THE HOOD

Training AI: from big LLMs to distilled Nexus models

If efficacy is the goal, the model has to be trained on the right data, but bigger isn't automatically better: large general-purpose LLMs are expensive to run and don't need to be that big for a security-specific job.

The Nexus model family is Proofpoint's answer: five distilled, purpose-built models rather than one giant generalist — Threat Intelligence, Machine Learning, Computer Vision, Language Models, and Relationship Graph — each doing one job well across the pipeline, and each retrained continuously as threat research feeds back in.

06 • WORKED EXAMPLES

Stopping AI-generated attacks: two worked examples

Two real lure types, and which Nexus model actually caught each one.

COLLAPSE ALL

01

The QR-code "DocuSign" phishing email

"Re: A document needs your signature"

QR / CREDENTIAL PHISHING



A spoofed "Laura at DocuSign" email asks the recipient to scan an embedded QR code, with a false 48-hour urgency deadline. Six separate signals flagged it: reply-to manipulation (ML), a suspicious display name

(RG), the QR code itself (Computer Vision), a suspicious URL (Threat Intelligence), urgent intent (Language Model), and a new malware variant (Human Risk Analytics).

WHY IT WORKS ON A PERSON QR codes dodge link-scanning tools and shift the click to an unmonitored phone.

02

The "Quick Task" gift-card BEC scam

"Ben Devons, COO" needs a favor

BEC / GIFT-CARD FRAUD ▼

An email impersonating "Ben Devons, COO" urgently asks for five \$50 gift cards, claiming he's unreachable by phone. No malware, no link, just social engineering, caught on relationship and intent signals: a suspicious, recently registered domain (RG, TI), a first-time recipient (RG), and detected purchase urgency (LM).

WHY CONTENT SCANNING MISSES IT There's nothing malicious to scan, which is why relationship and intent signals matter more here.

07 · SEEING THE WHOLE PICTURE

Visibility & human risk management

Detection only matters if it's visible: to the security team, and to the people being targeted.

One org's detection funnel: of 16.1M inbound messages, roughly 9.2M were caught as known-bad or learned threats, 6.9M were delivered, and 525 were automatically remediated after the fact.

Very Attacked People (VAPs): one org's 220 VAPs were targeted over 3.4x more than average, the case for prioritizing training and isolation by person,

not just by message, and for benchmarking risk against industry peers.

Human Risk Management closes the loop: signals from across the security stack feed a scoring back end, which surfaces risk indicators and profiles per person on a front-end dashboard, broken out by data, awareness, and threat risk.

08 · WRAP-UP

Closing summary

The full platform stacks all of this into one system: threat-protection, security-awareness, and data-security apps sit on Human Risk Analytics; the five Nexus models share one data layer underneath; and it's all enforced through a handful of control points, from the email gateway to browser, endpoint, and cloud connectors.

"There is no single right architecture, only the right combination of gateway, API, and human-centric controls for how your organization is already wired."

SESSION SYNTHESIS, BASED ON MATT COOKE'S CLOSING FRAMING

Unofficial personal notes on Proofpoint Cybersecurity Academy training, CLC: 2026 Certified AI Email Security Specialist, Session 2 of 3.

Next up: Session 3 of the AI Email Security Specialist path.